Advanced GRC Phishing Simulation & Quantitative Risk Analysis

GLOBALTECH INC.

Prepared by: Joan Kemboi
Date: 1 November 2026

Executive Summary

GlobalTech Inc. conducted three phishing simulations during the previous quarter to assess employee susceptibility to phishing and the potential business impact of compromised credentials. Across the three campaigns, 105 of 430 test emails resulted in credential submissions, giving a combined credential submission rate of 24.4%, assuming the campaign participants were unique.

Campaign B, the IT System Password Reset simulation, recorded the highest credential submission rate at 30%. Applying that rate to the organisation's 2,000 employees produces an estimated 600 employees whose credentials could be compromised. Under the lab's assumption that each compromised credential has a 25% chance of leading to a major breach, this represents 150 expected breach-equivalents. At an estimated $4.35 million per breach, the resulting modelled annualised exposure is $652.5 million.

The analysis identifies multi-factor authentication (MFA) as the strongest standalone investment in the supplied data. At an implementation cost of $90,000, its stated 99.9% effectiveness produces an estimated risk reduction benefit of $651.85 million and an ROI of 724,175%. Security awareness training also offers a strong projected return. An email-filtering estimate is included using an explicitly stated 20% risk-reduction assumption because the exercise does not provide a control-effectiveness figure for that option.

Results

Measure	Result	Interpretation
Combined simulation credential submission rate	24.4%	105 submissions from 430 test emails
Highest campaign credential submission rate	30.0% – Campaign B	Highest credential-submission proportion
Campaign B projected credential compromises	600 employees	30% applied to 2,000 employees
Modelled expected breach-equivalents	150	600 × 25% conditional probability
Modelled annualised exposure	$652,500,000	150 × $4.35 million
MFA implementation cost	$90,000	$45 per employee for 2,000 employees
MFA standalone ROI	724,175%	Based on $651.8475 million risk-reduction benefit

BASIC METRIC CALCULATIONS

Step 1: Fundamental Phishing Rates

The fundamental rates are calculated by dividing the number of employees who performed each action by the number of emails sent in that campaign, then multiplying by 100. The data-entry rate uses the number of employees who entered additional personal information as its numerator.

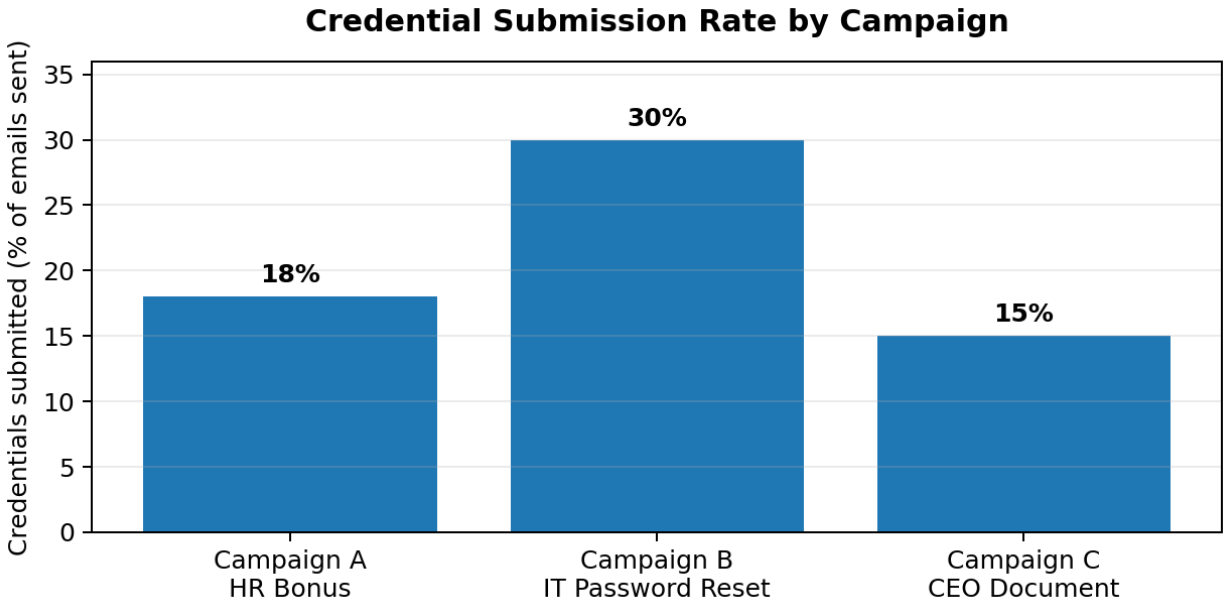
Campaign	Open rate	Click-through rate	Credential submission rate	Data-entry rate
A – HR Bonus Notification	82/100 = 82.0%	47/100 = 47.0%	18/100 = 18.0%	5/100 = 5.0%
B – IT Password Reset	200/250 = 80.0%	150/250 = 60.0%	75/250 = 30.0%	25/250 = 10.0%
C – CEO Document Review	72/80 = 90.0%	60/80 = 75.0%	12/80 = 15.0%	8/80 = 10.0%
Combined results	354/430 = 82.3%	257/430 = 59.8%	105/430 = 24.4%	38/430 = 8.8%

Step 2: Efficiency and Conversion Metrics

Conversion metrics show how employees progressed through the phishing attack sequence. The open-to-click rate measures the proportion of people who opened an email and then clicked its link. The post-click credential submission rate measures the proportion of people who clicked and subsequently submitted credentials.

Campaign	Open-to-click conversion	Post-click credential submission	Data entry among credential submitters
A	47/82 = 57.3%	18/47 = 38.3%	5/18 = 27.8%
B	150/200 = 75.0%	75/150 = 50.0%	25/75 = 33.3%
C	60/72 = 83.3%	12/60 = 20.0%	8/12 = 66.7%

Campaign C had the highest open-to-click conversion rate at 83.3%, showing that the executive-themed message was particularly effective at persuading people who opened it to click. Campaign B had the highest post-click credential submission rate at 50%, and also the highest overall credential submission rate at 30%. Campaign B is therefore the most successful campaign when success is measured by credential theft. Campaign C nevertheless deserves targeted attention because of the high response among executives and assistants and the high proportion of credential submitters who also entered personal information.



ADVANCED RISK QUANTIFICATION

Organisational Risk Exposure Projection

Campaign B recorded a credential submission rate of 75/250, or 30%. Applying this rate to 2,000 employees gives the projected number of employees whose credentials could be compromised.

- **Campaign B credential rate:** 75 ÷ 250 = 0.30 or 30%
- **Projected credentials compromised:** 2,000 × 0.30 = 600 employees
- **Expected breach-equivalents:** 600 × 0.25 = 150

The projection therefore produces 600 potentially compromised employee credentials and 150 expected breach-equivalents, using the lab's 25% probability of a major breach following credential theft. These are expected values generated by the exercise's model, rather than a count of observed breaches.

Financial Impact and Annualized Loss Expectancy

The estimated cost of a single major data breach is $4,350,000. The lab treats the 150 expected breach-equivalents as the annual rate of occurrence for the purpose of calculating Annualized Loss Expectancy (ALE).

- **Single Loss Expectancy (SLE):** Given in the scenario = $4,350,000
- **Annual Rate of Occurrence (ARO):** Expected breach-equivalents = 150 per year
- **Annualized Loss Expectancy:** $4,350,000 × 150 = $652,500,000

Security Control Effectiveness and Cost-Benefit Analysis

A. Multi-Factor Authentication (MFA)

The assignment gives an MFA implementation cost of $45 per employee and assumes a 99.9% reduction in the impact of credential theft. For 2,000 employees, the total implementation cost is $90,000.

Implementation cost: $45 × 2,000 users = $90,000

Risk-reduction benefit: $652,500,000 × 0.999 = $651,847,500

Residual ALE: $652,500,000 × 0.001 = $652,500

Net financial benefit: $651,847,500 − $90,000 = $651,757,500

ROI: ($651,847,500 − $90,000) ÷ $90,000 × 100 = 724,175%

On the assumptions provided, MFA offers the strongest standalone financial case. Its effectiveness assumption is unusually high and should be validated for the selected MFA method, implementation coverage, user adoption, recovery processes and resistance to phishing-resistant attacks. MFA reduces account compromise risk but should not be treated as eliminating all phishing-related losses.

B. Security Awareness Training

The proposed training programme costs $50 per employee, giving a total cost of $100,000. The lab assumes that training reduces the click-through rate by 60%. Starting with Campaign B's 30% credential submission rate, the assignment applies the 60% reduction to obtain a post-training rate of 12%.

Training cost: $50 × 2,000 users = $100,000

New rate used by the lab: 30% × (1 − 0.60) = 12%

Projected credentials compromised: 2,000 × 0.12 = 240 employees

Expected breach-equivalents: 240 × 0.25 = 60

New ALE: $4,350,000 × 60 = $261,000,000

Risk-reduction benefit: $652,500,000 − $261,000,000 = $391,500,000

Net financial benefit: $391,500,000 − $100,000 = $391,400,000

ROI: ($391,500,000 − $100,000) ÷ $100,000 × 100 = 391,400%

The calculation above follows the simplified method specified in the assignment. There is an important modelling assumption: the lab treats the new 12% click-through rate as the new credential submission rate. However, Campaign B shows that 50% of people who clicked went on to submit credentials. If that post-click conversion rate remained unchanged after training, a 12% click rate would imply a 6% credential submission rate, or 120 compromised credentials, rather than 240. The assignment's 240 figure is retained as the primary answer for consistency with its worked instructions.

C. Email Filtering

The executive briefing includes an email-filtering control costing $50,000 and states a risk-reduction benefit of $130.5 million. That benefit equals 20% of the current $652.5 million modelled exposure. The lab does not provide an email-filtering effectiveness percentage, so the 20% reduction must be treated as an illustrative assumption rather than a measured control result.

Assumed risk-reduction benefit: $652,500,000 × 0.20 = $130,500,000

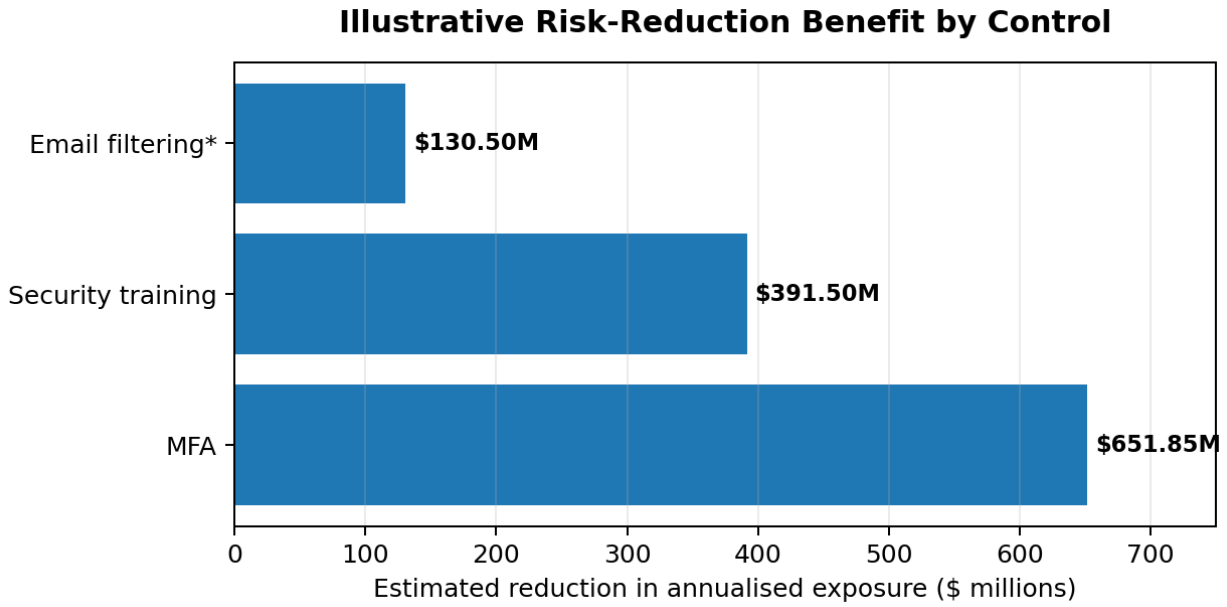
Net financial benefit: $130,500,000 − $50,000 = $130,450,000

ROI: ($130,500,000 − $50,000) ÷ $50,000 × 100 = 260,900%

The ROI is 260,900% using the stated $50,000 cost. The 260,800% figure in the assignment's draft table does not follow from the given benefit and cost.

Control	Cost	Risk-reduction benefit	Residual ALE	Net benefit	ROI
MFA	$90,000	$651,847,500	$652,500	$651,757,500	724,175%
Security training	$100,000	$391,500,000	$261,000,000	$391,400,000	391,400%
Email filtering*	$50,000	$130,500,000	$522,000,000	$130,450,000	260,900%

*Email filtering assumes a 20% reduction in the baseline exposure; the effectiveness percentage is not specified in the dataset. Benefits across controls are standalone estimates and must not be added together because they may overlap or mitigate the same attack path.



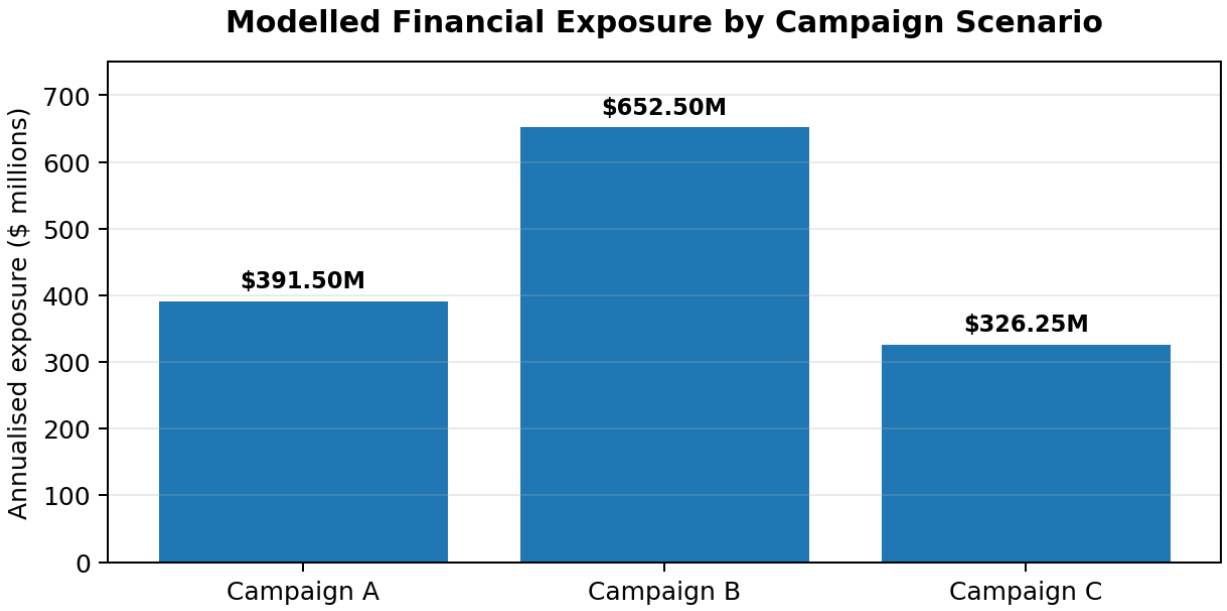
RISK ASSESSMENT

Risk Assessment Matrix

For comparison, each campaign's credential submission rate is projected across the 2,000-person workforce. The same 25% conditional probability of a major breach and $4.35 million cost per breach are applied to each scenario. The three financial projections are alternatives and should not be summed.

Campaign	Credential rate	Projected credentials	Expected breach-equivalents	Modelled exposure	Priority / response
A – HR Bonus	18%	2,000 × 18% = 360	360 × 25% = 90	$391,500,000	High – P2; targeted training
B – IT Password Reset	30%	2,000 × 30% = 600	600 × 25% = 150	$652,500,000	Critical – P1; immediate MFA
C – CEO Document	15%	2,000 × 15% = 300	300 × 25% = 75	$326,250,000	High – P3; executive-focused controls

Campaign B ranks first because it has the highest credential submission rate and the largest modelled exposure. Campaign A ranks second by projected financial exposure, followed by Campaign C. Campaign C should nevertheless receive focused executive and assistant training because it had the highest open-to-click conversion rate (83.3%) and the highest data-entry conversion among credential submitters (66.7%).



Statistical Significance and 95% Confidence Intervals

A 95% confidence interval estimates a range around the observed credential submission rate. The reference formula is $p \pm 1.96 \times \sqrt{[p(1 - p)/n]}$, where p is the observed rate and n is the number of employees in the sample.

Campaign A calculation

- **Observed credential rate (p):** 18 ÷ 100 = 0.18
- **Standard error:** $\sqrt{[0.18 \times 0.82 \div 100]} = \sqrt{0.001476} = 0.03842$
- **Margin of error:** 1.96 × 0.03842 = 0.07530 or 7.53 percentage points
- **Lower confidence limit:** 18% − 7.53% = 10.47%
- **Upper confidence limit:** 18% + 7.53% = 25.53%

The 95% confidence interval for Campaign A is therefore approximately 10.5% to 25.5%. In practical terms, based on this sample and the stated normal-approximation method, the underlying credential submission rate for the population represented by Campaign A is estimated to lie within this range.

Comparison with the other campaigns

Campaign	Observed credential rate	Sample size	95% confidence interval
A	18.0%	100	10.5% – 25.5%
B	30.0%	250	24.3% – 35.7%
C	15.0%	80	7.2% – 22.8%

Campaign B has the highest observed credential submission rate, but the confidence intervals for the campaigns overlap. Overlapping intervals mean the observed differences should be interpreted cautiously; confidence-interval overlap alone is not a formal test of whether two population rates differ significantly. The smaller samples in Campaign A and Campaign C also produce wider intervals. A formal two-proportion test, along with confirmation that the samples are independent and representative, would be needed before making a firm statistical-significance claim.

Executive Summary

GlobalTech Inc.'s three phishing simulations show that employees remain vulnerable to social-engineering attacks. Across the campaigns, 105 of 430 test emails resulted in credential submissions, equivalent to a combined rate of 24.4% if the campaign participants are unique. Campaign B recorded the highest credential submission rate at 30%. Applying this result to the organisation's 2,000 employees produces a scenario estimate of 600 potentially

compromised credentials and 150 expected breach-equivalents. Using the supplied average breach cost of $4.35 million, the resulting modelled annualised exposure is $652.5 million.

The organisation should prioritise phishing-resistant MFA, targeted security awareness training and improved email filtering. The financial results should be treated as scenario estimates pending validation of the assumptions, particularly the treatment of each compromised credential as a separate potential breach event.

Key Quantitative Findings

Risk metric	Assessment result	Reference comparison supplied in the brief
Combined credential submission rate	24.4%	15.3% industry figure supplied; source not provided
Highest campaign credential rate	30.0% – Campaign B	18.7% industry figure supplied; source not provided
Modelled ALE under Campaign B scenario	$652.5 million	$285 million comparison supplied; basis not provided
MFA standalone ROI	724,175%	350% comparison supplied; calculation basis not provided

3. Financial Analysis and Control Recommendations

The recommended standalone investments are summarised below. Risk-reduction benefit is the estimated financial exposure avoided; net benefit deducts the control cost; ROI is calculated as (benefit − cost) ÷ cost × 100.

Control	Cost	Risk reduction	Net benefit	ROI	Priority
MFA	$90,000	$651.85M	$651.76M	724,175%	1 – Immediate
Security training	$100,000	$391.50M	$391.40M	391,400%	2 – Immediate
Email filtering*	$50,000	$130.50M	$130.45M	260,900%	3 – High

4. Strategic Recommendations

Immediate actions should focus on the controls with the strongest direct relationship to credential compromise. GlobalTech should implement MFA across the workforce, prioritising phishing-resistant methods where feasible, and deliver targeted security awareness training based on campaign-specific behaviours. A continuing phishing simulation programme should be used to measure whether employee behaviour improves over time.

The organisation should also strengthen inbound email filtering and authentication, establish continuous security monitoring for suspicious account activity, and use security behaviour analytics to identify unusual access patterns. These supporting initiatives are included in the proposed budget below, but their individual financial effectiveness has not been quantified in the supplied dataset.

5. Proposed Security Investment Budget

Investment	Proposed cost	Purpose / treatment
Enterprise MFA implementation	$90,000	Reduce credential misuse and account takeover
Enhanced security awareness training	$100,000	Reduce susceptibility and improve reporting behaviour
Advanced email security gateway	$50,000	Filter malicious messages; 20% reduction used only as an estimate
Targeted phishing simulation programme	$25,000	Measure performance and identify high-risk groups
Continuous security monitoring	$150,000	Detect suspicious access and account activity
Security behaviour analytics	$75,000	Identify anomalous user and authentication behaviour
Total proposed investment	$490,000	Combined budget for the proposed programme

6. Expected Risk Posture After Controls

The assignment proposes a 90% reduction in overall risk for the combined control programme. Applying that assumption consistently to the $652.5 million baseline produces the following figures:

Measure	Current scenario	After assumed 90% reduction	Change
Campaign B credential submission rate	30.0%	3.0%	90% lower
Modelled annualised loss exposure	$652.50M	$65.25M	$587.25M reduction
Overall breach probability	Not established	Not calculable from supplied data	Further modelling required

Portfolio risk-reduction benefit: $652,500,000 × 0.90 = $587,250,000

Residual annualised exposure: $652,500,000 × 0.10 = $65,250,000

First-year net benefit: $587,250,000 − $490,000 = $586,760,000

Illustrative portfolio ROI: ($587,250,000 − $490,000) ÷ $490,000 × 100 = 119,746.94%

These portfolio figures are conditional on achieving the assumed 90% overall reduction. The individual MFA, training and email-filtering benefits cannot be added to derive a portfolio benefit because their effects overlap and the effectiveness of several supporting initiatives is not provided. The 90% combined reduction should be treated as a planning target until it is supported by control testing and post-implementation simulation data.

BREAK-EVEN ANALYSIS

The break-even calculation compares the total proposed security investment of $490,000 with the estimated cost of one major data breach, $4,350,000.

Break-even number of breaches: $490,000 ÷ $4,350,000 = 0.1126 breaches

The organisation therefore needs to prevent approximately 0.113 of an expected breach event to recover the proposed investment on an expected-value basis. In practical terms, preventing one full breach would avoid approximately $4.35 million in loss, which is about 8.9 times the $490,000 investment. The proposed programme breaks even if it reduces expected breach losses by at least $490,000 over the period being evaluated.

Conclusion

The phishing simulations show measurable human risk at GlobalTech Inc. Campaign B produced the highest credential submission rate and should guide immediate credential-protection measures. Campaign A also presents a material projected financial exposure, while Campaign C highlights the need for tailored protection and awareness for executives and their assistants.

The supplied model produces a $652.5 million annualised exposure under the Campaign B scenario. While this figure depends on simplified assumptions and should be validated before being used as a formal forecast, it demonstrates how phishing simulation results can be translated into financial terms for risk prioritisation and budget discussions. MFA, security awareness training and stronger email controls are recommended, supported by ongoing monitoring and repeat simulations to measure actual risk reduction.